Security Assessment Report

TARGET URL	https://holynamemabelreign.org/
SCAN ID	–
GENERATED	2026-05-22 13:56 UTC

0/100 Security Score — Critical Risk

Executive Summary

21 security issues were detected across this scan. These findings should be reviewed and remediated promptly.

HTTP Header Issues	9
OWASP ZAP Alerts	1
Sensitive File Exposure	5

Detailed Findings

✓ SQL Injection Analysis
No issues detected

✓ No SQL injection vulnerabilities were detected.

✓ SSL/TLS Certificate
Valid certificate

Issuer	Let's Encrypt
Subject	holynamemabelreign.org
Expires	Jul 22 00:55:59 2026 GMT
Protocol	TLSv1.3

✗ HTTP Header Security
9 issues found

Missing content-security-policy	High

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.

content-security-policy was not present in the response.

Missing strict-transport-security — Medium

strict-transport-security was not present in the response.

Missing x-content-type-options — Medium

x-content-type-options was not present in the response.

Missing x-frame-options — Medium

x-frame-options was not present in the response.

Missing referrer-policy — Low

referrer-policy was not present in the response.

Missing permissions-policy — Low

permissions-policy was not present in the response.

Missing cross-origin-opener-policy — Medium

cross-origin-opener-policy was not present in the response.

Missing cross-origin-resource-policy — Low

cross-origin-resource-policy was not present in the response.

Information disclosure via server — Low

server: cloudflare

- Add a Content-Security-Policy header to defend against XSS.
- Enable HSTS to force browsers to use HTTPS.
- Set X-Content-Type-Options: nosniff to prevent MIME sniffing.
- Set X-Frame-Options to DENY or SAMEORIGIN to block clickjacking.
- Set Referrer-Policy to control how much referrer info is sent.
- Add a Permissions-Policy header to restrict browser feature access.
- Add Cross-Origin-Opener-Policy: same-origin to prevent Spectre-style cross-origin attacks.
- Add Cross-Origin-Resource-Policy: same-origin to prevent cross-site resource loading.
- Suppress or genericise the Server header to avoid version disclosure.

WordPress Security

Not a WordPress site

No WordPress installation detected on this target.

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.

✗ OWASP ZAP Analysis

1 alert

ZAP scan failed — Info

HTTPConnectionPool(host='localhost', port=8080): Max retries exceeded with url: http://zap/JSON/core/view/version/ (Caus

✓ Malicious Content Analysis

No threats detected

✓ **No malicious indicators detected.**

Threat Score: 0/10

✓ Cross-Site Scripting (XSS)

No reflected XSS detected

✓ **No reflected XSS vectors detected in tested parameters.**

Content-Security-Policy header missing — Medium

No CSP detected — add one as a defence-in-depth measure

✓ Technology Fingerprinting

No actionable technology issues

Cdn	Cloudflare

✓ **No risky technology exposure indicators detected.**

✗ Sensitive File Exposure

5 paths exposed

`https://holynamemabelreign.org/sitemap.xml` 537 bytes

```
mlns="http://www.sitemaps.org/schemas/sitemap/0.9">
priority>1.0</priority></url>
loc><priority>0.8</priority></url>
s</loc><priority>0.8</priority></url>
</loc><priority>0.7</priority></url>
</loc><priority>0.6</priority></url> </urlset>
```

https://holynamemabelreign.org/config/credentials.yml.enc [rub

```
et="utf-8"/><link rel="icon" href="/images/logo.jpg"/><link
.org"/><link rel="apple-touch-icon" href="/images/logo.jpg"/><meta
ial-scale=1"/><meta name="theme-color" content="#1B3A6B"/><meta
hurch Harare - Parish website for news, events, and community
//fonts.googleapis.com"><link rel="preconnect"
nk
aleway:ital,wght@0,300;1,300&display=swap" rel="stylesheet"><link
aleway:ital,wght@0,200;1,200&display=swap" rel="stylesheet"><link
aleway:ital@0;1&display=swap" rel="stylesheet"><link rel="manifest"
 Church</title><script defer="defer"
 href="/static/css/main.c6433c65.css" rel="stylesheet"></head><body
vaScript to run this app.</noscript><div
{var b=a.contentDocument||a.contentWindow.document;if(b){var
__CF$cv$params={r:'9ffc5228ac5d95ed',t:'MTc3OTQ1ODE1MQ=='};var a=docu
llenge-platform/scripts/jsd/main.js';document.getElementsByTagName('h
('head')[0].appendChild(d)}}if(document.body){var a=document.createEl
ition='absolute';a.style.top=0;a.style.left=0;a.style.border='none';a
hild(a);if('loading'!==document.readyState)c();else
ener('DOMContentLoaded',c);else{var e=document.onr
```

https://holynamemabelreign.org/terraform.tfvars [devops] 2,174

```
et="utf-8"/><link rel="icon" href="/images/logo.jpg"/><link
.org"/><link rel="apple-touch-icon" href="/images/logo.jpg"/><meta
ial-scale=1"/><meta name="theme-color" content="#1B3A6B"/><meta
hurch Harare - Parish website for news, events, and community
//fonts.googleapis.com"><link rel="preconnect"
nk
aleway:ital,wght@0,300;1,300&display=swap" rel="stylesheet"><link
aleway:ital,wght@0,200;1,200&display=swap" rel="stylesheet"><link
aleway:ital@0;1&display=swap" rel="stylesheet"><link rel="manifest"
 Church</title><script defer="defer"
 href="/static/css/main.c6433c65.css" rel="stylesheet"></head><body
vaScript to run this app.</noscript><div
{var b=a.contentDocument||a.contentWindow.document;if(b){var
__CF$cv$params={r:'9ffc525f6a1b95ed',t:'MTc3OTQ1ODE2MA=='};var a=docu
llenge-platform/scripts/jsd/main.js';document.getElementsByTagName('h
('head')[0].appendChild(d)}}if(document.body){var a=document.createEl
ition='absolute';a.style.top=0;a.style.left=0;a.style.border='none';a
hild(a);if('loading'!==document.readyState)c();else
ener('DOMContentLoaded',c);else{var e=document.onr
```

https://holynamemabelreign.org/cgi-bin/test-cgi [php] 2,174 by

```
et="utf-8"/><link rel="icon" href="/images/logo.jpg"/><link
.org"/><link rel="apple-touch-icon" href="/images/logo.jpg"/><meta
ial-scale=1"/><meta name="theme-color" content="#1B3A6B"/><meta
hurch Harare - Parish website for news, events, and community
//fonts.googleapis.com"><link rel="preconnect"
nk
aleway:ital,wght@0,300;1,300&display=swap" rel="stylesheet"><link
aleway:ital,wght@0,200;1,200&display=swap" rel="stylesheet"><link
aleway:ital@0;1&display=swap" rel="stylesheet"><link rel="manifest"
 Church</title><script defer="defer"
 href="/static/css/main.c6433c65.css" rel="stylesheet"></head><body
vaScript to run this app.</noscript><div
{var b=a.contentDocument||a.contentWindow.document;if(b){var
__CF$cv$params={r:'9ffc52c1fac595ed',t:'MTc3OTQ1ODE3Ng=='};var a=docu
llenge-platform/scripts/jsd/main.js';document.getElementsByTagName('h
('head')[0].appendChild(d)}}if(document.body){var a=document.createEl
ition='absolute';a.style.top=0;a.style.left=0;a.style.border='none';a
hild(a);if('loading'!==document.readyState)c();else
ener('DOMContentLoaded',c);else{var e=document.onr
```

https://holynamemabelreign.org/rails/info/routes [ruby] 2,174

```
et="utf-8"/><link rel="icon" href="/images/logo.jpg"/><link
.org"/><link rel="apple-touch-icon" href="/images/logo.jpg"/><meta
ial-scale=1"/><meta name="theme-color" content="#1B3A6B"/><meta
hurch Harare - Parish website for news, events, and community
//fonts.googleapis.com"><link rel="preconnect"
nk
aleway:ital,wght@0,300;1,300&display=swap" rel="stylesheet"><link
aleway:ital,wght@0,200;1,200&display=swap" rel="stylesheet"><link
aleway:ital@0;1&display=swap" rel="stylesheet"><link rel="manifest"
 Church</title><script defer="defer"
 href="/static/css/main.c6433c65.css" rel="stylesheet"></head><body
vaScript to run this app.</noscript><div
{var b=a.contentDocument||a.contentWindow.document;if(b){var
__CF$cv$params={r:'9ffc52c96c0f95ed',t:'MTc3OTQ1ODE3Nw=='};var a=docu
llenge-platform/scripts/jsd/main.js';document.getElementsByTagName('h
('head')[0].appendChild(d)}}if(document.body){var a=document.createEl
ition='absolute';a.style.top=0;a.style.left=0;a.style.border='none';a
hild(a);if('loading'!==document.readyState)c();else
ener('DOMContentLoaded',c);else{var e=document.onr
```

- Never expose CI/CD configs, Dockerfiles, or cloud credentials via HTTP.
- Move Rails config files above the web root and restrict access via your web server.
- Block access to sensitive files via Nginx `deny all` or Apache `Require all denied` directives.
- Remove debug pages and backup files from the PHP web root; use `.htaccess` or Nginx rules.

✗ **DNS Security (SPF / DMARC / DKIM)**
5 issues

No SPF record — High

No SPF TXT record found for holynamemabelreign.org. Attackers can send spoofed email appearing to come from this domain.

No DMARC record — High

No DMARC TXT record found at _dmarc.holynamemabelreign.org. Without DMARC, SPF and DKIM results are not enforced.

No DKIM record found (common selectors checked) — Medium

None of the common DKIM selectors (default, google, mail, k1, selector1, selector2, dkim, email, smtp) returned a DKIM1

DNSSEC not enabled — Low

No DS or DNSKEY records found for holynamemabelreign.org. DNSSEC prevents DNS cache poisoning attacks.

No CAA record — Low

No CAA record for holynamemabelreign.org. Any CA can issue certificates for this domain.

- Add an SPF record: v=spf1 include: -all
- Add a DMARC record: v=DMARC1; p=quarantine; rua=mailto:dmarc-reports@yourdomain.com
- Configure DKIM signing on your mail server and publish the public key as a TXT record at ._domainkey..
- Enable DNSSEC for your domain — configure it at your DNS registrar and publish DS records.
- Add CAA records to restrict which certificate authorities may issue certificates for your domain. Example: 0 issue "letsencrypt.org"

✓ **Open Redirect**
Pass

✓ No open redirect vulnerabilities detected.

✓ **Subdomain Takeover**
Pass

✓ No dangling CNAMEs or unclaimed service fingerprints found across 2 subdomains.

Conclusion & Recommended Next Steps

1. HTTP Headers	Add missing security headers (CSP, HSTS, X-Frame-Options, etc.).
2. ZAP Alerts	Triage each alert and patch confirmed vulnerabilities.
3. File Exposure	Block sensitive paths in the web server and rotate any exposed credentials.
4. DNS Security	Configure SPF (-all), DMARC (p=quarantine or reject), DKIM signing, and CAA records.

Developer Best Practices

- Adopt secure-by-default output encoding and enforce a strict Content-Security-Policy across all templates and SPAs.
- Standardize security headers and cookie flags in a shared middleware layer so new vibecoded pages inherit safe defaults.
- Keep source, backup, env, and debug artifacts out of the web root, and validate deployment bundles before publish.
- Use authenticated code review and protected branches even for AI-generated code; fast generation increases the need for release guardrails.
- Add pre-production checks for secrets, dependency risk, headers, and exposed debug routes before every deployment.

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.